GoPhish

Cybersécurité — Simulation de Phishing

Core Pack

En bref

GoPhish est une plateforme open-source de simulation de phishing. Elle permet d'envoyer de faux emails frauduleux aux collaborateurs du client pour tester leur vigilance, mesurer le taux de clics, et identifier les personnes à former. C'est un outil à fort impact commercial : les dirigeants **voient concrètement** le risque cyber de leur entreprise, ce qui justifie toute la stack sécurité.

Point clé

GoPhish est le meilleur **outil de vente** de la stack sécurité. Un rapport de campagne montrant 40% de taux de clic convainc n'importe quel dirigeant de l'utilité d'un SIEM et d'une formation.

1 Ce que voit le client

Ce que voit et ressent le client

« Vous nous avez envoyé un faux email de phishing la semaine dernière — 12 de nos 30 collaborateurs ont cliqué et entré leur mot de passe. On a reçu un rapport détaillé avec les noms et les départements concernés. On a pu former immédiatement les personnes à risque. »

Gains mesurables :

- Réduction du taux de clic de **40% → 5%** après 3 campagnes de sensibilisation
- Preuve de formation pour les assurances cyber (tarifs réduits)
- Rapport PDF automatique généré par n8n après chaque campagne
- Conformité aux recommandations ANSSI et RGPD sur la sensibilisation

2 Installation technique

Prérequis : Domaine d'envoi dédié (ex : `securite-alerte.fr`) différent du domaine client, SPF/DKIM configurés, VPS séparé recommandé pour éviter toute association avec l'infrastructure principale.

Listing 1 – docker-compose.yml — GoPhish

```yaml
version: "3.8"
services:
  gophish:
    image: gophish/gophish:latest
    restart: always
    ports:
      - "3333:3333"   # Admin UI (interne uniquement)
      - "80:80"       # Landing pages HTTP
      - "443:443"     # Landing pages HTTPS
    volumes:
      - ./config.json:/opt/gophish/config.json
      - ./ssl:/opt/gophish/ssl
      - gophish_data:/opt/gophish/db
    environment:
      GOPHISH_INITIAL_ADMIN_PASSWORD: ${GOPHISH_ADMIN_PASSWORD}

volumes:
  gophish_data:
```

Listing 2 – Configuration DNS du domaine d'envoi

```
# DNS du domaine de simulation (ex: securite-alerte.fr)
# Enregistrements SPF
securite-alerte.fr. TXT "v=spf1 ip4:VPS_IP -all"

# DKIM (générer avec opendkim-genkey)
mail._domainkey.securite-alerte.fr. TXT "v=DKIM1; k=rsa; p=MIGfMA..."

# DMARC
_dmarc.securite-alerte.fr. TXT "v=DMARC1; p=reject;
    rua=mailto:dmarc@jlax-expertise.fr"

# MX (pour les out-of-office de retour)
securite-alerte.fr. MX 10 mail.securite-alerte.fr.
```

3 Configuration de base

Workflow d'une campagne type :

1. **Sending Profile** : serveur SMTP du domaine d'envoi dédié, `From: Sécurité IT <noreply@securite-alerte.`
2. **Email Template** : imiter un email Microsoft / DHL / impôts (selon le secteur client)
3. **Landing Page** : fausse page de connexion qui capture le clic (sans stocker les mots de passe réels)
4. **Users & Groups** : importer la liste des collaborateurs (CSV : prénom, nom, email, département)
5. **Campaign** : lancer sur 3 jours, horaires bureaux (9h-17h)
6. **Results** : exporter CSV → n8n génère le rapport PDF → envoi au dirigeant

4 Intégration dans la stack

Outil	Rôle
n8n	Déclenchement de campagnes planifiées, récupération des résultats, génération rapport PDF
OpenAI API	Génération automatique de templates d'emails de phishing réalistes
MS Graph API	Import automatique de la liste des collaborateurs depuis Azure AD
Grafana	Dashboard de suivi : taux de clic par campagne, évolution dans le temps

5 Rendre invisible côté client

— **Accord écrit obligatoire** du dirigeant avant toute campagne (clause dans le contrat)
— Les collaborateurs **ne savent pas** que des tests sont effectués — c'est le principe
— Le domaine d'envoi **ne ressemble pas** au domaine Jlax pour éviter toute confusion
— L'interface admin GoPhish n'est accessible qu'en interne (pas de lien public)
— Après la campagne : le dirigeant reçoit le rapport, il gère la communication interne

Attention

Obtenir systématiquement une **autorisation écrite signée** avant toute campagne de phishing. Cette autorisation doit préciser la période, les cibles et l'objectif. Sans cela, l'opération peut être considérée comme une attaque réelle.

Maintenance mensuelle

☐ Vérifier que le domaine d'envoi n'est pas en liste noire (MXToolbox → Blacklist check)
☐ Tester l'envoi d'un email de test depuis le domaine dédié

- ☐ Planifier la prochaine campagne trimestrielle avec le dirigeant
- ☐ Archiver les résultats de la campagne précédente
- ☐ Vérifier le renouvellement SSL du domaine de landing pages